

DBMS cPP Version 2.0 Diff from Review Draft

Baseline: 10dde95 - removed pdf headers / footers

Compared to: current working tree final publication source

Generated: 2026-06-25 15:57:22 UTC

+72 additions

-71 deletions

```
diff --git a/cPP/DBMS_cPP-working_copy.adoc b/cPP/DBMS_cPP-working_copy.adoc
index 2190b2a..520142b 100644
--- a/cPP/DBMS_cPP-working_copy.adoc
+++ b/cPP/DBMS_cPP-working_copy.adoc
@@ -74,39 +74,39 @@ Although the cPPs and SDs may contain minor editorial errors, cPPs are recognize

The following documents are available from the CC Portal at https://www.commoncriteriaportal.org/

Common Criteria

-[%header,cols="1,1"]
+[cols="1,1"]

|===
|[[CC1]]
-|Common Criteria for Information Technology Security Evaluation, + Part 1: Introduction and General Model, + ISO/IEC 15408-1:2022.
+|Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and general model, CCMB-2022-11-001, CC:2022 Revision 1, November 2022.

|[[CC2]]
-|Common Criteria for Information Technology Security Evaluation, + Part 2: Security Functional Components, + ISO/IEC 15408-2:2022.
+|Common Criteria for Information Technology Security Evaluation, Part 2: Security functional requirements, CCMB-2022-11-002, CC:2022 Revision 1, November 2022.

|[[CC3]]
```

-|Common Criteria for Information Technology Security Evaluation, + Part 3: Security Assurance Components, + ISO/IEC 15408-3:2022.

+|Common Criteria for Information Technology Security Evaluation, Part 3: Security assurance requirements, CCMB-2022-11-003, CC:2022 Revision 1, November 2022.

|[CC4]

-|Common Criteria for Information Technology Security Evaluation, + Part 4: Framework for the specification of evaluation methods and activities, + ISO/IEC 15408-4:2022.

+|Common Criteria for Information Technology Security Evaluation, Part 4: Framework for the specification of evaluation methods and activities, CCMB-2022-11-004, CC:2022 Revision 1, November 2022.

|[CC5]

-|Common Criteria for Information Technology Security Evaluation, + Part 5: Pre-defined packages of security requirements, + ISO/IEC 15408-5:2022.

+|Common Criteria for Information Technology Security Evaluation, Part 5: Pre-defined packages of security requirements, CCMB-2022-11-005, CC:2022 Revision 1, November 2022.

+|[CCE]

+|Common Criteria for Information Technology Security Evaluation, Errata and interpretation for CC:2022 (Release 1) and CEM:2022 (Release 1), CCMB-002, Version 1.1, July 22, 2024.

|[CEM]

-|Evaluation Methodology for IT Security, + ISO/IEC 18045:2022.

+|Common Methodology for Information Technology Security Evaluation, Evaluation methodology, CCMB-2022-11-006, CEM:2022, Revision 1, November 2022.

|===

Documents related to this cPP

-%header,cols="1,1"]

+ [cols="1,1"]

|===

|[SD]

|Supporting Document Mandatory Technical Document Evaluation Activities for the collaborative Protection Profile for Database Management Systems, Version 2.0, 27 April 2026

-|

-|

|===

Other Documents

-%header,cols="1,1"]

+ [cols="1,1"]

|===

| [DBMSiTC]

| DBMS iTC Status <https://www.commoncriteriaportal.org/files/communities/Status.DBMS.pdf>

| [TD_DBMS_B_001]

| Technical Decision TD_DBMS_B_001: Update to Role Definitions and Security Attribute Management for Consistency, published 29 July 2025

@@ -118,25 +118,25 @@ Other Documents

Except for replacing United Kingdom spelling with American spelling, the notation, formatting, and conventions used in this cPP are consistent with CC:2022. Selected presentation choices are discussed here to aid the cPP reader.

The CC allows several operations to be performed on functional requirements; refinement, selection, assignment, and iteration are defined in clause 8 of Part 1 of the CC [CC1]. Each of these operations is used in this Protection Profile (PP).

-The refinement operation is used to add detail to a requirement, and thus further restricts a requirement. Refinement of security requirements is denoted by bold text or in the case of deletions, by crossed out bold text.

+The **refinement** operation is used to add detail to a requirement, and thus further restricts a requirement. Refinement of security requirements is denoted by **bold text** or in the case of deletions, by **++++++crossed out bold text++++++**.

-The selection operation is used to select one or more options provided by the CC in stating a requirement. Selections that have been made by the PP authors are denoted by italicized text, selections to be filled in by the Security Target (ST) author appear in square brackets with an indication that a selection is to be made, [selection:], and are not italicized.

+The **selection** operation is used to select one or more options provided by the CC in stating a requirement. Selections that have been made by the PP authors are denoted by *_italicized text_*, selections to be filled in by the Security Target (ST) author appear in square brackets with an indication that a selection is to be made, [selection:], and are not italicized.

-The assignment operation is used to assign a specific value to an unspecified parameter, such as the length of a password. Assignments that have been made by the cPP authors are denoted by showing the value in square brackets, [assignment_value], assignments to be filled in by the ST author appear in square brackets with an indication that an assignment is to be made [assignment:]. Assignments within selections are denoted by showing the value in square brackets and italics [*assignment_value*].

+The **assignment** operation is used to assign a specific value to an unspecified parameter, such as the length of a password. Assignments that have been made by the cPP authors are denoted by showing the value in square brackets, [assignment_value], assignments to be filled in by the ST author appear in square brackets with an indication that an assignment is to be made [assignment:]. Assignments within selections are denoted by showing the value in square brackets and italics [*_assignment_value_*].

-The iteration operation is used when a component is repeated with varying operations.

+The **iteration** operation is used when a component is repeated with varying operations.

Iteration is denoted by showing the iteration number in parenthesis following the component identifier, (iteration number).

The CC paradigm also allows protection profile authors to create their own requirements. Such requirements are termed “extended requirements” and are permitted if the CC does not offer suitable requirements to meet the author’s needs. Extended requirements must be identified and are required to use the CC class/family/component model in articulating the requirements. In this cPP, extended requirements will be indicated with the “_EXT” following the component name.

Application Notes are provided to help the developer, either to clarify the intent of a requirement, identify implementation choices, or to define “pass-fail” criteria for a requirement. For those components where Application Notes are appropriate, the Application Notes will follow the requirement component. They are numbered and formatted thus:

-_This is an application note._

+_Application Note 1: This is an application note._

=== Revision History

[%header,cols="1,1,1"]

|===

@@ -241,13 +241,13 @@ A DBMS supports two user types:

* The authorized administrators who implement and manage the various information-related policies of an organization (e.g., access, integrity, consistency, availability) for the databases that they install, configure, manage, and/or own.

A DBMS stores and controls access to two types of data:

* The first type is the user data that the DBMS maintains and protects. User data may consist of the following:

-* The user data stored in or as database objects;

-* The definitions of user databases and database objects, commonly known as DBMS metadata; and

-* The user-developed queries, functions, or procedures that the DBMS maintains for users.

*** The user data stored in or as database objects;

*** The definitions of user databases and database objects, commonly known as DBMS metadata; and

*** The user-developed queries, functions, or procedures that the DBMS maintains for users.

* The second type is the DBMS data (e.g., configuration parameters, user security attributes, transaction log, audit instructions, and records) that the DBMS maintains and may use to operate the DBMS.

DBMS specifications identify the detailed requirements for the DBMS server functions given in the above list.

==== Security Functionality Provided by the TOE

@@ -269,15 +269,13 @@ The TOE consists of at least one instance of the security functions of the DBMS

This cPP does not dictate a specific architecture. The ST writer will need to identify and describe the TOE architecture to be evaluated. Architectures are described in section 1.4.2.

The external IT entities, with which the DBMS may interact, may include the following:

-Client applications that allow users to interface with the DBMS server.

-

-The host operating system (host OS) on which the TOE has been installed;

-

-The networking, printing, data-storage, and other devices and services with which the host OS may interact on behalf of the DBMS or the DBMS user; and the other IT products such as application servers, web servers, authentication servers, directory services, and transaction processors with which the DBMS may interact to perform a DBMS function or a security function.

+* Client applications that allow users to interface with the DBMS server.

+* The host operating system (host OS) on which the TOE has been installed.

+* The networking, printing, data-storage, and other devices and services with which the host OS may interact on behalf of the DBMS or the DBMS user; and the other IT products such as application servers, web servers, authentication servers, directory services, and transaction processors with which the DBMS may interact to perform a DBMS function or a security function.

The TOE Security Function (TSF) is limited to the elements required to exercise the evaluated security functionality.

The DBMS must specify the host OS on which it must reside to provide the desired degree of security feature integration as well as the configuration of those OS(es) required to support the DBMS functions. In all cases, the TOE must be installed and administered in accordance with the TOE installation and administration instructions.

@@ -311,11 +309,11 @@ Authorized administrators of the TOE will have capabilities that are commensurat

== Conformance Claims

=== Conformance with CC

-This cPP conforms to the requirements of Common Criteria:2022 as defined by the references [CC1], [CC2] and [CC3]. The framework for the specification of evaluation activities is defined in [CC4], the assurance package is defined in [CC5], and the methodology applied for the PP evaluation is defined in [CEM].

+This cPP conforms to the requirements of Common Criteria:2022 as defined by the references [CC1], [CC2] and [CC3]. The framework for the specification of evaluation activities is defined in [CC4], the assurance package is defined in [CC5], and the methodology applied for the PP evaluation is defined in [CEM]. This cPP also accounts for errata and interpretations for CC:2022 and CEM:2022 [CCE].

This cPP applies exact conformance, selection-based SFRs, and optional SFRs as defined for CC:2022.

This cPP satisfies the following Assurance Families: APE_CCL.1, APE_ECD.1, APE_INT.1, APE_OBJ.2, APE_REQ.2 and APE_SPD.1.

@@ -534,11 +532,11 @@ The TSF shall be able to generate audit data of the following auditable events:

The TSF shall record within the audit data at least the following information:

* Date and time of the auditable event, type of event, subject identity (if applicable), and the outcome (success or failure) of the event; and

* For each auditable event type, based on the auditable event definitions of the functional components included in the PP, PP-Module, functional package or ST, [information specified in column three of Table 4: Auditable Events].

-_In column 3 of the table below, “Additional Audit Data Contents” is used to designate data that should be included in the audit data if it “makes sense” in the context of the event which generates the data. If no other information is required (other than that listed in item a) above) for a particular auditable event type, then an assignment of “none” is acceptable._

+_Application Note 1: In column 3 of the table below, “Additional Audit Data Contents” is used to designate data that should be included in the audit data if it “makes sense” in the context of the event which generates the data. If no other information is required (other than that listed in item a) above) for a particular auditable event type, then an assignment of “none” is acceptable._

.Table 4: Auditable Events

[%header,cols="1,1,1"]

|==

|Column 1: Security Functional Requirement

@@ -611,11 +609,11 @@ _In column 3 of the table below, “Additional Audit Data Contents” is used to

FAU_GEN.2 User identity association

====

FAU_GEN.2.1

-For audit events resulting from actions of identified users, the TSF shall be able to associate each auditable event with the identity of the user that caused the event.

+For audit events resulting from actions of identified users *and any identified groups*, the TSF shall be able to associate each auditable event with the identity of the [selection: user, user and group] that caused the event.

==== Security audit event selection (FAU_SEL)

[BOILERPLATE]

====

@@ -624,17 +622,17 @@ For audit events resulting from actions of identified users, the TSF shall be ab

FAU_SEL.1.1

The TSF shall be able to select the set of events to be audited from the set of all auditable events based on the following attributes:

-* user identity;

-* [selection: object identity, user identity, subject identity, host identity, group identity, event type, success of auditable security events, failure of auditable security events];

+* *user identity*;

+* [selection: object identity, *++++++user identity++++++*, subject identity, host identity, group identity, event type, success of auditable security events, failure of auditable security events];

* [assignment: list of additional attributes that audit selectivity is based upon].

-_“event type” is to be defined by the ST author; the intent is to be able to include or exclude classes of audit events._

+_Application Note 2: “event type” is to be defined by the ST author; the intent is to be able to include or exclude classes of audit events._

-_The intent of this requirement is to capture sufficient audit data to allow the administrators to perform their tasks; additional audit data may be captured._

+_Application Note 3: The intent of this requirement is to capture sufficient audit data to allow the administrators to perform their tasks; additional audit data may be captured._

=== Class: User Data Protection (FDP)

==== Access control policy (FDP_ACC)

@@ -643,11 +641,11 @@ _The intent of this requirement is to capture sufficient audit data to allow the

FDP_ACC.1 Subset access control

====

FDP_ACC.1.1

-The TSF shall enforce the [Discretionary Access Control policy] on all subjects, all DBMS-controlled objects, and all operations among them.

+The TSF shall enforce the [Discretionary Access Control policy] on [all subjects, all DBMS-controlled objects, and all operations among them].

==== Access control functions (FDP_ACF)

[BOILERPLATE]

====

@@ -656,13 +654,13 @@ The TSF shall enforce the [Discretionary Access Control policy] on all subjects,

FDP_ACF.1.1

The TSF shall enforce the [Discretionary Access Control policy] to objects based on the following: [assignment: list of subjects and objects controlled under the indicated SFP, and for each, the SFP-relevant security attributes, or named groups of SFP-relevant security attributes].

-_DBMS-controlled objects may be implementation-specific objects that are presented to authorized users at the user interface to the DBMS. They may include, but are not limited to tables, records, files, indexes, views, constraints, stored queries, and metadata. Data structures that are not presented to authorized users at the DBMS user interface, but are used internally, are internal TSF data structures. Internal TSF data structures are not controlled according to the rules specified in FDP_ACF.1._

+_Application Note 4: DBMS-controlled objects may be implementation-specific objects that are presented to authorized users at the user interface to the DBMS. They may include, but are not limited to tables, records, files, indexes, views, constraints, stored queries, and metadata. Data structures that are not presented to authorized users at the DBMS user interface, but are used internally, are internal TSF data structures. Internal TSF data structures are not controlled according to the rules specified in FDP_ACF.1._

-_Named groups of security attributes can be specified to provide a convenient means to refer to multiple security attributes. In this PP, 'Named group of SFP-relevant security attributes' refers to a group of attributes that can be associated with an object or a subject. For example, this could be a named Access Control List (ACL)._

+_Application Note 5: Named groups of security attributes can be specified to provide a convenient means to refer to multiple security attributes. In this PP, 'Named group of SFP-relevant security attributes' refers to a group of attributes that can be associated with an object or a subject. For example, this could be a named Access Control List (ACL)._

FDP_ACF.1.2

The TSF shall enforce the following rules to determine if an operation among controlled subjects and controlled objects is allowed: [assignment: rules governing access among controlled subjects and controlled objects using controlled operations on controlled objects].

@@ -685,11 +683,11 @@ The TSF shall explicitly deny access of subjects to objects based on the followi

The TSF shall ensure that any previous information content of a resource is made unavailable upon the allocation of the resource to the following objects: [assignment: list of objects].

=== Class: Identification and authentication (FIA)

-_It is drawn to the attention of the ST writer that the identification and authentication family was written in such a way that the SFRs might be used in either the case that Identification and Authentication (I&A) services are performed by the TOE itself or that they are performed within the TOE environment._

+_Application Note 6: It is drawn to the attention of the ST writer that the identification and authentication family was written in such a way that the SFRs might be used in either the case that Identification and Authentication (I&A) services are performed by the TOE itself or that they are performed within the TOE environment._

==== User authentication (FIA_UAU)

[BOILERPLATE]

====

@@ -713,11 +711,11 @@ The TSF shall maintain the following list of security attributes belonging to in

- * Database user identifier and any associated group memberships;
- * Security-relevant database roles; and
- * [assignment: list of security attributes].

-_The intent of this requirement is to specify the TOE security attributes that the TOE utilizes to determine access. These attributes may be controlled by the environment or by the TOE itself._

+_Application Note 7: The intent of this requirement is to specify the TOE security attributes that the TOE utilizes to determine access. These attributes may be controlled by the environment or by the TOE itself._

==== User identification (FIA_UID)

[BOILERPLATE]

====

@@ -757,15 +755,15 @@ The TSF shall enforce the [Discretionary Access Control policy] to restrict the

FMT_MSA.3.1

The TSF shall enforce the [Discretionary Access Control policy] to provide restrictive default values for security attributes that are used to enforce the SFP.

-_This requirement applies to new objects at the top-level (e.g., tables). When lower-level objects are created (e.g., rows, cells), these may inherit the permissions of the top-level objects by default. In other words, the permissions of the 'child' objects can take the permissions of the 'parent' objects by default._

+_Application Note 8: This requirement applies to new objects at the top-level (e.g., tables). When lower-level objects are created (e.g., rows, cells), these may inherit the permissions of the top-level objects by default. In other words, the permissions of the 'child' objects can take the permissions of the 'parent' objects by default._

FMT_MSA.3.2

-The TSF shall allow the [no user] to specify alternative initial values to override the default values when an object or information is created.

+The TSF shall allow *++++++the++++++* [no user] to specify alternative initial values to override the default values when an object or information is created.

==== Management of TSF data (FMT_MTD)

[BOILERPLATE]

====

@@ -778,11 +776,11 @@ The TSF shall restrict the ability to [include or exclude] the [auditable events

==== Revocation (FMT_REV)

[BOILERPLATE]

====

-*FMT_REV.1(1) Revocation*

+*FMT_REV.1(1) Revocation (Users)*

====

FMT_REV.1.1(1)

The TSF shall restrict the ability to revoke [assignment: list of security attributes] associated with the users under the control of the TSF to [authorized administrator].

@@ -791,11 +789,11 @@ The TSF shall restrict the ability to revoke [assignment: list of security attri

The TSF shall enforce the rules [assignment: specification of revocation rules].

[BOILERPLATE]

====

-*FMT_REV.1(2) Revocation (DAC)*

+*FMT_REV.1(2) Revocation (Objects)*

====

FMT_REV.1.1(2)

The TSF shall restrict the ability to revoke [assignment: list of security attributes] associated with the objects under the control of the TSF to [authorized administrator, authorized users].

@@ -833,11 +831,11 @@ The TSF shall be capable of performing the following security management functio

[assignment: any additional security management functions required to configure the claimed security]

].

-_The ST author should ensure that all security attributes identified in FIA_ATD.1 are adequately managed and protected._

+_Application Note 9: The ST author should ensure that all security attributes identified in FIA_ATD.1 are adequately managed and protected._

==== Security management roles (FMT_SMR)

[BOILERPLATE]

====

@@ -850,13 +848,13 @@ The TSF shall maintain the roles [authorized administrator, authorized users, an

FMT_SMR.1.2

The TSF shall be able to associate users with roles.

-_The authorized users role defined in FMT_SMR.1.1 is referenced in FMT_REV.1.1(2) and FMT_MSA.1.1(2) for objects._

+_Application Note 10: The authorized users role defined in FMT_SMR.1.1 is referenced in FMT_REV.1.1(2) and FMT_MSA.1.1(2) for objects._

-_This requirement identifies a minimum set of management roles. An ST may describe, or an operational environment may contain a finer-grain decomposition of roles that correspond to the roles identified here (e.g., database non-administrative user or database operator). The ST author may change the names of the roles identified above but the “new” roles must still perform the functions that the security management requirements in this cPP have defined. It is not necessary to list roles that are not exercised in the evaluated configuration._

+_Application Note 11: This requirement identifies a minimum set of management roles. An ST may describe, or an operational environment may contain a finer-grain decomposition of roles that correspond to the roles identified here (e.g., database non-administrative user or database operator). The ST author may change the names of the roles identified above but the “new” roles must still perform the functions that the security management requirements in this cPP have defined. It is not necessary to list roles that are not exercised in the evaluated configuration._

=== Class: TOE access (FTA)

==== Configurable Session Limiting Mechanisms (FTA_MCS_EXT)

@@ -871,11 +869,11 @@ The TSF shall restrict the maximum number of concurrent sessions based on [selec

FTA_MCS_EXT.1.2

The TSF shall provide the capability for an authorized administrator to configure the selected enforcement mechanism(s).

-_If "User session locking as defined by FTA_MCS.1" is selected in FTA_MCS_EXT.1.1, then FTA_MCS.1 must also be included from Appendix D._

+_Application Note 12: If "User session locking as defined by FTA_MCS.1" is selected in FTA_MCS_EXT.1.1, then FTA_MCS.1 must also be included from Appendix D._

==== TOE session establishment (FTA_TSE)

[BOILERPLATE]

====

@@ -985,29 +983,29 @@ ST authors are free to choose none, some or all SFRs defined in this chapter. It

[BOILERPLATE]

====

FIA_USB_EXT.2 Enhanced user-subject binding

====

-*FIA_USB_EXT.2 .1*

+*FIA_USB_EXT.2.1*

The TSF shall associate the following user security attributes with subjects acting on the behalf of that user: [assignment: list of user security attributes].

-*FIA_USB_EXT.2 .2*

+*FIA_USB_EXT.2.2*

The TSF shall enforce the following rules on the initial association of user security attributes with subjects acting on the behalf of users: [assignment: rules for the initial association of attributes].

-*FIA_USB_EXT.2 .3*

+*FIA_USB_EXT.2.3*

The TSF shall enforce the following rules governing changes to the user security attributes associated with subjects acting on the behalf of users: [assignment: rules for the changing of attributes].

-*FIA_USB_EXT.2 .4*

+*FIA_USB_EXT.2.4*

-The TSF shall enforce the following rules for the assignment of subject security attributes not derived from user security attributes when a subject is created: [assignment: rules for the initial association of the subject security attributes not derived from user security attributes].

+*The TSF shall enforce the following rules for the assignment of subject security attributes not derived from user security attributes when a subject is created: [assignment: rules for the initial association of the subject security attributes not derived from user security attributes].*

-_Some administrative tasks may be delegated to specific users (which by that delegation become administrators although they can only perform some limited administrative actions). Ensuring that those users cannot extend the administrative rights assigned to them is a security functionality the TOE has to provide._

+_Application Note 13: Some administrative tasks may be delegated to specific users (which by that delegation become administrators although they can only perform some limited administrative actions). Ensuring that those users cannot extend the administrative rights assigned to them is a security functionality the TOE has to provide._

-_If FIA_USB_EXT.2 is included in an ST then Table 4: Auditable Events is refined to add the following entry:_

+_Application Note 14: If FIA_USB_EXT.2 is included in an ST then Table 4: Auditable Events is refined to add the following entry:_


```
[%header,cols="1,1,1"]
```

```
|===
```

```
|Column 1: Security Functional Requirement
```

```
|Column 2: Auditable Event(s)
```

```
@@ -1032,11 +1030,11 @@ The TSF shall ensure that TSF data is consistent when replicated between parts o
```

```
*FPT_TRC.1.2*
```

When parts of the TOE containing replicated TSF data are disconnected, the TSF shall ensure the consistency of the replicated TSF data upon reconnection before processing any requests for [assignment: list of functions dependent on TSF data replication consistency].

-_In general, it is impossible to achieve complete, constant consistency of TSF data that is distributed to remote portions of a TOE because distributed portions of the TSF may be active at different times or disconnected from one another. This requirement attempts to address this situation in a practical manner by acknowledging that there will be TSF data inconsistencies but that they will be corrected without undue delay. For example, a TSF could provide timely consistency through periodic broadcast of TSF data to all TSF nodes maintaining replicated TSF data. Another example approach is for the TSF to provide a mechanism to explicitly probe remote TSF nodes for inconsistencies and respond with action to correct the identified inconsistencies._

+_Application Note 15: In general, it is impossible to achieve complete, constant consistency of TSF data that is distributed to remote portions of a TOE because distributed portions of the TSF may be active at different times or disconnected from one another. This requirement attempts to address this situation in a practical manner by acknowledging that there will be TSF data inconsistencies but that they will be corrected without undue delay. For example, a TSF could provide timely consistency through periodic broadcast of TSF data to all TSF nodes maintaining replicated TSF data. Another example approach is for the TSF to provide a mechanism to explicitly probe remote TSF nodes for inconsistencies and respond with action to correct the identified inconsistencies._

```
=== Class: TOE access (FTA)
```

```
==== TOE access information (FTA_TAH_EXT)
```

```
@@ -1059,11 +1057,11 @@ attempt(s).
```

Upon successful session establishment, the TSF shall allow the date and time of

* the previous last successful session establishment, and

* the last unsuccessful attempt to session establishment and the number of unsuccessful attempts since the previous last successful session establishment to be retrieved by the user.

-_If FTA_TAH_EXT.1 is included in an ST then Table 4: Auditable Events is refined to add the following entry:_

+_Application Note 16: If FTA_TAH_EXT.1 is included in an ST then Table 4: Auditable Events is refined to add the following entry:_

[%header,cols="1,1,1"]

|===

|Column 1: Security Functional Requirement

|Column 2: Auditable Event(s)

@@ -1131,11 +1129,11 @@ The TSF shall enforce the following rules on the initial association of user sec

The TSF shall enforce the following rules governing changes to the user security attributes associated with subjects acting on the behalf of users: [assignment: rules for the changing of attributes].

FIA_USB_EXT.2.4

-The TSF shall enforce the following rules for the assignment of subject security attributes not derived from user security attributes when a subject is created: [assignment: rules for the initial association of the subject security attributes not derived from user security attributes].

+*The TSF shall enforce the following rules for the assignment of subject security attributes not derived from user security attributes when a subject is created: [assignment: rules for the initial association of the subject security attributes not derived from user security attributes].*

=== Class: TOE access (FTA)

==== Limitation on multiple concurrent sessions (FTA_MCS_EXT)

@@ -1143,20 +1141,23 @@ The TSF shall enforce the following rules for the assignment of subject security

This family defines requirements to place limits on the number of concurrent sessions.

==== Component levelling

+FTA_MCS_EXT.1 is not hierarchical to any other components.

+

[#img-FTA-MCS-EXT]

.Component levelling

[ditaa, fta_mcs_ext_leveling, png]

....

-+-----+

-| FTA_MCS_EXT.1 |

-| Basic limitation on |

-| multiple concurrent |

-| sessions |

-+-----+

+

+ +-----+

+ | | +---+

+ | FTA_MCS_EXT Session Limitation | +-+--> | 1 |

+ | | +---+

+ +-----+

+

....

==== Management

The following actions could be considered for the management functions in FMT:

@@ -1170,20 +1171,20 @@ The following actions should be auditable if FAU_GEN Security audit data generat

* rejection of a new session based on the limitation of multiple concurrent sessions

===== Dependencies

-FIA_UID.1 Timing of identification

+FIA_UID.2 User identification before any action

[BOILERPLATE]

=====

FTA_MCS_EXT.1 Configurable Session Limiting Mechanisms

=====

Hierarchical to: No other components.

-Dependencies: FIA_UID.1 Timing of identification

+Dependencies: FIA_UID.2 User identification before any action

FTA_MCS_EXT.1.1

The TSF shall restrict the maximum number of concurrent sessions based on [selection: User session locking as defined by FTA_MCS.1, [assignment: mechanism(s) for session limitation enforced by the TSF]].

@@ -1452,11 +1453,11 @@ The table below provides a rationale for the environmental security objectives.

|OE.IT_I&A supports the assumption implicitly.

|A.MANAGE The TOE security functionality is managed by one or more competent, authorized administrators. The system administrative personnel are not careless, willfully negligent, or hostile, and will follow and abide by the instructions provided by the guidance documentation.

|OE.ADMIN Those responsible for the TOE are competent and trustworthy individuals, capable of managing the TOE and the security of information it contains.

|OE.ADMIN supports the assumption by requiring that authorized administrators are competent, thereby ensuring that all the tasks are performed correctly and effectively.

|

-|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authentication databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

+|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authorization databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

|OE.INFO_PROTECT supports the assumption by ensuring that users are authorized to access the appropriate data, and are trained to exercise control.

|A.NO_GENERAL + _PURPOSE There are no general-purpose computing capabilities (e.g., compilers or user applications) available on DBMS servers, other than those services necessary for the operation, administration, and support of the DBMS.

|OE.NO_GENERAL_PURPOSE There shall be no general-purpose computing capabilities (e.g., compilers or user applications) available on DBMS servers, other than those services necessary for the operation, administration, and support of the DBMS.

|OE.NO_GENERAL_PURPOSE The DBMS server must not include any general-purpose computing capabilities. This will protect the TSF data from malicious processes.

|A.PEER_FUNC_&_MGT All external trusted IT systems trusted by the TSF to provide TSF data or services to the TOE, or to support the TSF in the enforcement of security policy decisions are assumed to correctly implement the functionality used by the TSF consistent with the assumptions defined for this functionality and to be properly managed and operate under security policy constraints compatible with those of the TOE.

@@ -1464,14 +1465,14 @@ The table below provides a rationale for the environmental security objectives.

|OE.IT_TRUSTED_SYSTEM supports this assumption by ensuring that remote systems supporting the TOE are managed in a manner consistent with the security policies applicable to the TOE.

|A.PHYSICAL The operational environment is assumed to provide the TOE with appropriate physical protection such that the TOE is not subject to physical attack that may compromise the security and/or

interfere with the platform's correct operation. This includes protection for the physical infrastructure on which the TOE depends for correct operation and hardware devices on which the TOE is executing.

|OE.PHYSICAL Those responsible for the TOE shall ensure that those parts of the TOE critical to enforcement of the security policy are protected from physical attack that might compromise IT security objectives. The protection shall be commensurate with the value of the IT assets protected by the TOE.

|OE.PHYSICAL supports this assumption by ensuring that the parts of the TOE critical to the enforcement of the security policy are protected from physical attack.

|

-|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authentication databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

+|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authorization databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

|OE.INFO_PROTECT supports the assumption by requiring that all network and peripheral cabling must be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques.

|A.TRAINEDUSER Authorized users are sufficiently trained to accomplish a task or group of tasks within a secure IT environment by exercising control over their user data.

-|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authentication databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

+|OE.INFO_PROTECT Those responsible for the TOE shall establish and implement procedures to ensure that information is protected in an appropriate manner. In particular: All network and peripheral cabling shall be approved for the transmittal of the most sensitive data transmitted over the link. Such physical links are assumed to be adequately protected against threats to the confidentiality and integrity of the data transmitted using appropriate physical and logical protection techniques. DAC protections on security-relevant files (such as audit trails and authorization databases) shall always be set up correctly. Users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

|OE.INFO_PROTECT supports the assumption by ensuring that users are authorized to access parts of the data managed by the TOE and are trained to exercise control over their own data.

|P.USER Authority shall only be given to users who are trusted to perform the actions correctly.

|OE.ADMIN Those responsible for the TOE are competent and trustworthy individuals, capable of managing the TOE and the security of information it contains.

|OE.ADMIN supports the policy by ensuring that the authorized administrators, responsible for granting authority to users, are trustworthy.

|

@@ -1495,20 +1496,20 @@ The following table provides the rationale for the selection of the security fun

|O.ADMIN_ROLE The TOE shall provide roles that allow only authorized users to have access to administrative privileges that are specific to the role.

|FMT_SMR.1

|The TOE will establish, at least, an authorized administrator role and authorized user roles. Additional roles may also be specified.

|O.AUDIT_GENERATION The TOE shall provide the capability to detect and create records of security relevant events associated with users.

|FAU_GEN.1 FAU_GEN.2 FAU_SEL.1

-|FAU_GEN.1 defines the set of events for which the TOE must be capable of generating audit data. This requirement ensures that the administrator has the ability to audit any security relevant events that takes place in the TOE. This requirement also defines the information that must be contained in the audit data for each auditable event. FAU_GEN.2 ensures that the audit data associates a user identity with the auditable event. FAU_SEL.1 allows the administrator to configure which auditable events will be recorded in the audit trail.

+|FAU_GEN.1 defines the set of events for which the TOE must be capable of generating audit data. This requirement ensures that the administrator has the ability to audit any security relevant events that takes place in the TOE. This requirement also defines the information that must be contained in the audit data for each auditable event. FAU_GEN.2 ensures that the audit data associates a user identity and, when applicable, a group identity with the auditable event. FAU_SEL.1 allows the administrator to configure which auditable events will be recorded in the audit trail.

|O.DISCRETIONARY_ACCESS The TSF shall control access of subjects and/or users to named resources based on identity of the object, subject or user. The TSF shall allow authorized users to specify for each access mode which users/subjects are allowed to access a specific named object in that access mode.

|FDP_ACC.1 FDP_ACF.1

|The TSF controls access to resources based on the subject and/or object security attributes.

|O.I&A The TOE shall ensure that users are authenticated before the TOE processes any actions that require authentication.

|FIA_ATD.1 FIA_UAU.2 FIA_UID.2 FIA_USB_EXT.2 (Optional)

-|FIA_UID.2 and FIA_UAU.2 ensure that only authorized users gain access to the TOE and its resources following identification and authentication. FIA_ATD.1 ensures that the security attributes used to determine access are defined and available to the support access control decisions. FIA_USB_EXT.2 ensures enforcement of the rules governing subjects acting on behalf of authorized users.

+|FIA_UID.2 and FIA_UAU.2 ensure that only authorized users gain access to the TOE and its resources following identification and authentication. FIA_ATD.1 ensures that the security attributes used to determine access are defined and available to support access control decisions. FIA_USB_EXT.2 ensures enforcement of the rules governing subjects acting on behalf of authorized users.

|O.MANAGE The TSF shall provide all the functions and facilities necessary to manage TOE security mechanisms, and shall restrict such management actions to authorized users.

|FMT_MSA.1(1) FMT_MSA.1(2) FMT_MSA.3 FMT_MTD.1 FMT_REV.1(1) FMT_REV.1(2) FMT_SMF.1 FMT_SMR.1

-|FMT_MSA.1 ensures that the ability to perform operations on security attributes is restricted to authorized administrators and authorized users. FMT_MSA.3 ensures that default values used for security attributes are restrictive. FMT_MTD.1 ensures that the ability to include or exclude auditable events is restricted to authorized administrators. FMT_REV.1 restricts the ability to revoke attributes to the authorized administrator and authorized users. FMT_SMF.1 identifies the management functions that are available to the authorized administrator. FMT_SMR.1 defines the specific security roles to be supported.

+|FMT_MSA.1(1) and FMT_MSA.1(2) ensure that the ability to perform operations on security attributes is restricted to authorized administrators and authorized users. FMT_MSA.3 ensures that default values used for security attributes are restrictive. FMT_MTD.1 ensures that the ability to include or exclude auditable events is restricted to authorized administrators. FMT_REV.1(1) and FMT_REV.1(2) restrict the ability to revoke attributes to the authorized administrator and authorized users. FMT_SMF.1 identifies the management functions that are available to the authorized administrator. FMT_SMR.1 defines the specific security roles to be supported.

|O.RESIDUAL_INFORMATION The TOE shall ensure that any information contained in a protected resource within its control is not inappropriately disclosed when the resource is reallocated.

|FDP_RIP.1

|FDP_RIP.1 ensures that the contents of resources are not available upon reallocation of the resource.

|O.TOE_ACCESS The TOE shall provide mechanisms that control a user's logical access to user data and to the TSF.

|FDP_ACC.1 FDP_ACF.1 FIA_ATD.1 FTA_MCS_EXT.1 FTA_MCS.1 (Selection-Based) FTA_TSE.1 FTA_TAH_EXT.1 (Optional) FPT_TRC.1 (Optional)

@@ -1578,12 +1579,12 @@ The following table provides the rationale for the selection of the security fun

|This requirement is satisfied by FIA_UID.2 which is hierarchical to FIA_UID.1.

|FPT_TRC.1

|FPT_ITT.1

|For a distributed TOE, the dependency is satisfied through the environmental assumption, A.CONNECT, that assures the confidentiality and integrity of the transmitted data.

|FTA_MCS_EXT.1

-|FIA_UID.1

-|This requirement is satisfied by FIA_UID.2 which is hierarchical to FIA_UID.1.

+|FIA_UID.2

+|This requirement is satisfied by FIA_UID.2.

|FTA_MCS.1

|FIA_UID.1

|When FTA_MCS.1 is selected through FTA_MCS_EXT.1, this requirement is satisfied by FIA_UID.2 which is hierarchical to FIA_UID.1.

|FTA_TSE.1

|None

@@ -1644,11 +1645,11 @@ The TSF shall restrict the maximum number of concurrent sessions that belong to

FTA_MCS.1.2

The TSF shall enforce, by default, a limit of [assignment: default number] sessions per user.

-_The ST author is reminded that CC Part 2 [CC2] allows that the default number may be defined as a management function in FMT._

+_Application Note 17: The ST author is reminded that CC Part 2 [CC2] allows that the default number may be defined as a management function in FMT._

== Glossary

The terms, definitions and abbreviations given [CC1] apply to this document. Additional terms, definitions and abbreviations applicable only within the DBMS cPP context are given below: